

INCIDENT RESPONSE PLAYBOOK: PHISHING EMAIL COMPROMISE

**Prepared By Ugochukwu Princewill Okafor as My
Techcrush Project.**

PURPOSE

This playbook provides a structured approach for detecting, containing, eradicating, and recovering from phishing email compromise incidents. Its objective is to minimize business impact and restore normal operations as quickly as possible.

APPLICABILITY

This playbook applies to all employees, contractors, and systems within the organization that may be affected by phishing emails, credential theft, or email account compromise.

Roles and responsibilities:

SECURITY

Investigate reported phishing emails.

Analyse indicators of compromise (IOC).

IT SUPPORT TEAM

Reset compromised accounts.

Isolate affected systems if necessary.

Coordinate containment and eradication activities.	Restore services and assist users.
Document findings and lessons learned.	

EMPLOYEES

MANAGEMENT

Report suspicious emails immediately.	Approve communication strategies.
Avoid clicking links or opening unexpected attachments.	Provide support and resources during incident response.
Cooperate with the investigation process.	

IDENTIFICATION

Receive phishing reports from users or monitoring tools.

Review email headers and sender information.

Determine whether links or attachments were accessed.

Identify affected users and systems.

Collect evidence, including screenshots and email copies.

CONTAINMENT

Block malicious sender addresses and domains.

Remove phishing emails from user mailboxes.

Disable compromised accounts if unauthorized access is suspected.

Revoke active sessions and tokens.

Isolate affected devices when necessary.

ERADICATION

Remove malicious files or software.

Reset passwords for affected users.

Enforce multi-factor authentication (MFA).

Update email security filters and detection rules.

Conduct malware scans on impacted systems.

RECOVERY

Restore normal access for affected users.

Monitor accounts for suspicious activities.

Verify that systems are functioning correctly.

Inform users of actions taken and any required follow-up steps.

POST-INCIDENT ACTIVITIES

Conduct a lessons-learned meeting.

Update phishing awareness training materials.

Improve security controls based on findings.

Document the incident timeline and response actions.

Revise the playbook if gaps are identified.

Indicators of Compromise (IOCs)

Suspicious email sender addresses.

Unexpected password reset notifications.

Unauthorized mailbox rules.

Login attempts from unusual locations.

Unexpected forwarding rules.

Users reporting credential submission on fake websites.

COMMUNICATION PLAN

Notify the Security Team immediately.

Inform affected users of required actions.

Escalate significant incidents to management.

Maintain accurate records of all communications.

SUCCESS METRICS

Malicious emails are contained promptly.

Compromised accounts are secured.

Business operations resume with minimal disruption.

Lessons learned are documented and implemented.